# Setnayan — Data Retention Schedule

> **Revised 2026-10-22** — current enforcement, measured in code (`origin/main` `aceb080a0a`): chat 5 years after the event (`retention-sweep`); **face selfie + vector erased when Papic closes, 12 hours after the event**, backstop 92 days (`face-selfie-papic-close`, `face-data-retention`); supplier identity uploads 90 days after the decision, DTI / BIR 2303 / Mayor's Permit 7 years (`vendor-identity-retention`); Deep Search dossiers 180 days; full-resolution originals replaced by the web copy at 6 months from first capture (≥ 3 months after the event) — **the compressed gallery is kept for life**; unanswered connection requests 30 days; anonymous drafts 30 days; group stories 24 hours; site-visit hashes 1 day. Payments / receipts / contracts: **10 years** per the live `/privacy`. **Promised on `/privacy` but no purge found in code:** support tickets 2 years, our error/usage logs 90 days, stale device records 24 months. **Account deletion has no tail** — request → 24-hour admin review → anonymise-and-retain. Class 9 (observability): PostHog removed 2026-10-22; Sentry only. All jobs are cron-free (run on request traffic). Where the body below differs, this line governs.

> **Status: DRAFT — `[PENDING COUNSEL]`.** Retention periods below are reasoned from the standard PH statutes (RA 10173, NIRC/BIR, Civil Code). They are **not legal advice** and must be ratified by external counsel before launch. **DPO = the owner** (Indalecio S. Casasola II) per `[[dpo-designation-owner]]`; external counsel = TBD.

> Created 2026-07-11. This is the canonical answer to "how long do we keep user data, and until when *can* we keep it?" — supersedes scattered "5-year" mentions in individual iteration specs.

---

## 1. Governing principles

Retention is bounded on **both** ends, and the two bounds come from different laws pulling in opposite directions:

| Bound | Source | Effect |
|---|---|---|
| **Maximum** (delete *by*) | RA 10173 (Data Privacy Act) — **storage-limitation principle** | Personal data may be kept **only as long as necessary** for its purpose, then must be securely disposed of. Indefinite retention of personal data is itself a violation and a breach-surface liability. "Keep everything forever" is **not** an option for personal data. |
| **Minimum** (cannot delete *before*) | NIRC / BIR **RR 17-2013**; Civil Code **Art. 1144** | Financial/tax records must be kept **10 years**; a written contract is actionable for **10 years**, so contract records must survive that dispute window. These **override** an earlier RA 10173 erasure for the specific records they cover. |

**Design consequence:** a chat thread and the payment attached to it are **different retention classes**. You cannot anchor everything to one "delete at N years" switch — you would either illegally delete a tax record or needlessly hoard chat. Retention is **per data class**, below.

---

## 2. Retention schedule (by data class)

| # | Data class | Iteration(s) | Retention anchor | Keep for | Legal basis | Disposal |
|---|---|---|---|---|---|---|

| | | | | | | |
|---|---|---|---|---|---|---|
| 1 | **Vendor↔couple chat** (`chat_threads`, `chat_messages`) | 0019 | `event_date` | **5 years** | RA 10173 necessity + normal dispute window | Hard-delete thread + messages |

| | | | | | | |
|---|---|---|---|---|---|---|
| 2 | **Media** — Papic photos/video, gallery, reels (R2) | 0012, 0009, 0024 | **first capture** (NOT `event_date`), floored at `event_date` + 3 months | **Full-res 6 months from the event's FIRST capture and never less than 3 months after the event date, then ONE compression to the ~8% web copy — free,** FOR LIFE **— owner 2026-08-18, *"we keep it for life"*, superseding the five-year window set on 2026-08-07, which had itself superseded the 2026-07-10 "free forever" lock.** There is no end date and no paid tier. **[X]** Nothing was ever deleted under any of the three rulings **— only the ORIGINAL's resolution ever changes. (!) The withdrawn paid option was never built and never priced, so this retires a PROMISE, not a product. This pack is unsigned and unfiled, so no superseded figure was ever declared to the Commission.** (owner-locked 2026-07-10 "free forever, never deleted"; window 3 mo → 6 mo owner 2026-08-02; post-event floor 30 d → 3 mo and capture opening 5 mo → 6 mo owner 2026-08-07). (!) **CORRECTED 2026-08-02** — this row previously read *"5 years (hot 90 d → cold → purge)"*, which described a deletion the product does not perform. (!) **ANCHOR CORRECTED 2026-08-07** — it said `event_date`; the clock actually starts at the **first capture**, which can be six months earlier, so an `event_date` anchor overstates how long we hold an engagement-shoot original. A schedule promising a purge that never happens is the more dangerous direction of drift: it is a commitment to the regulator broken every day. The couple's own Google Drive full-res is separate and permanent (2026-07-11 invariant) — we never downgrade or delete THEIR copy. | RA 10173 — see (!) below; PH photographer norm | R2 lifecycle: compression at 6 mo; **no expiry rule on the web copy** |

(!) **INDEFINITE RETENTION IS A LAWFUL-BASIS QUESTION, NOT A STORAGE SETTING (flagged 2026-08-02).**
Row 2 now states that the compressed web copy is kept forever. That is the shipped product and the owner's lock — but RA 10173 asks that personal data be kept no longer than the purpose requires, and these are photographs of identifiable people, including guests who are not our customers. The basis is the couple's own request to preserve their memories, plus guest consent captured at RSVP/tag time, plus the standing opt-out and face-blur path. **That reasoning must be written down and reviewed by counsel before this schedule is lodged** — 'the owner decided' is not a lawful basis. Until then this row is accurate about what we DO, and unproven about whether we MAY.
| 3 | **Payments / receipts / Official Receipts** | 0026, 0034 | payment date | **10 years** — *legal floor, cannot delete early* | BIR RR 17-2013 | Purge at 10 y |
| 4 | **Contracts + e-signatures** | 0032 | contract execution date | **10 years** | Civil Code Art. 1144 prescription | Purge at 10 y |
| 5 | **Account / profile PII** (`users`, settings) | 0025 | account close / deletion request | **Life of account + 30–90 day tail**, then purge | RA 10173 storage limitation | Soft-delete → hard-delete after tail |
| 6 | **Face-recognition vectors** (`face_enrollments`) | 0012 | `event_date` | **Per-event only; revocable on request. (!) CORRECTED 2026-08-07 — this read "purge with media (≤5 y)". The media row was corrected 2026-08-02 to retain the compressed copy INDEFINITELY, so "purge with media" silently became "never purged" and this row was not re-read. Nothing in the codebase deletes a face vector on a schedule — only erasure-on-request does. There is currently NO automatic end date. Whether one is required under the storage-limitation principle is an OPEN DPO question, not a settled rule.** | RA 10173 sensitive data; per-event-scoped lock | Delete on revoke or at media purge |
| 7 | **Marketing consent / comms prefs** | 0025, 0028 | last consent change | Life of account + audit tail | RA 10173 / CAN-SPAM proof-of-consent | Purge with account |
| 8 | **Support tickets / help-center** | 0029 | ticket close | **2 years** | Operational necessity | Purge at 2 y |
| 9 | **Observability / logs** (Sentry, PostHog) | 0035 | event timestamp | Provider default (≤**90 days**); **no PII in logs** | RA 10173 data-minimization | Provider TTL |
| 10 | **Device-fingerprint hashes** (`user_devices.device_hash`) — fraud prevention | Fake-Inquiry Protection (Phase E) | `last_seen_at` | **Life of account**; rolling-prune device rows unused **> 24 mo** (proposed) | RA 10173 §12(f) legitimate interest (fraud prevention); pseudonymous, non-sensitive | Purge with account (class 5 tail) or on rolling prune |

### The clocks, stated plainly

- **Chat = 5 years**, anchored to `event_date`.
- **Media has its OWN clock and it is not five years** (see row 2, and § "Papic media" below). (!) **CORRECTED 2026-08-07** — this line previously read *"Default = 5 years for the experience data (chat + media)"*, which **contradicted row 2 of this same document** and restated the very claim row 2 exists to retract. *A schedule that records the decision in one row and contradicts it three lines later will be read from whichever line the reader hits first* — and this is the summary, so it is the line most people hit.
- **Legal-hold floor = 10 years** for anything touching **money or a contract** — flagged and **exempt** from the sweep.

### Papic media — the three numbers, and how they interlock (owner-locked 2026-08-07)

| | value | where it is enforced |
|---|---|---|

| | | |
|---|---|---|
| Cameras may start shooting | **6 months** before the event | `PAPIC_CAPTURE_MONTHS_BEFORE` |
| Full-res ORIGINAL held at full resolution | **6 months** from the event's **first capture** | `DEFAULT_FULL_RES_RETENTION_DAYS = 183` |
| …but never less than | **3 months after the event date** | `FULL_RES_POST_EVENT_GRACE_DAYS = 92` |
| The phrase itself (compressed copy) | **free,** FOR LIFE **— owner 2026-08-18, *"we keep it for life"*, superseding the five-year window set on 2026-08-07, which had itself superseded the 2026-07-10 "free forever" lock.** There is no end date and no paid tier. **[X]** Nothing was ever deleted under any of the three rulings **— only the ORIGINAL's resolution ever changes. (!) The withdrawn paid option was never built and never priced, so this retires a PROMISE, not a product. This pack is unsigned and unfiled, so no superseded figure was ever declared to the Commission.** | no expiry rule in code |

The eligibility rule is `GREATEST(first_capture + 183d, event_date + 92d)` in migration `20271102113000` — the **later** of the two, so the floor can only ever hold the original at full resolution for longer.

## NO PHOTO IS EVER DELETED — SAY "COMPRESSED", NOT "DELETED"

**Owner-corrected twice, most recently 2026-08-07: *"again. not delete. just compress."*** This is the single most-repeated wording error on this product, so it is stated here rather than assumed.

**Nothing disappears from a customer's gallery, ever.** A compressed copy of every photo is derived at capture time and kept **free, for life** (owner 2026-08-18, *"we keep it for life"*, superseding the 2026-08-07 five-year window — and **nothing is deleted at 5 years**). What the window above governs is **resolution**: at the end of it, the full-resolution *original file* is replaced by that compressed copy.

[OK] **The code enforces this and cannot do otherwise.** `isEligibleForDrop` (`lib/papic-fullres-drop-core.ts`) returns `false` when no compressed copy exists — its own comment reads *"dropping would LOSE the photo"* — and the clip path additionally requires the web copy to be a **distinct object** from the poster still. There is no code path that removes an original before its replacement exists.

**House wording, lifted verbatim from the warning email (copy this, do not invent new phrasing):**

> *"Your gallery stays online forever, free. We'll switch the full-resolution copies we host to a lighter, compressed version — that compressed gallery stays online for you forever. Your gallery keeps every photo; we just won't be holding the*

> *full-resolution originals after that."*

[X] Never write, in any customer-facing surface: *deleted · we delete your photos · purged · removed · gone · lost · expires · auto-delete*. [OK] Write: *compressed · replaced by a compressed copy · we keep a compressed copy forever*.

(!) This carve-out does **not** apply to features that genuinely delete — a host removing a photo, an RA 10173 erasure request, account deletion, the 5-year chat sweep. Those really do delete and must keep saying so.

**The third number is the promise, not the second.** Because shooting may open six months before the event, a photo taken at the earliest permitted moment has its own six-month clock expire **on the wedding day itself**. Every day a couple keeps their originals *after* their own wedding is bought by the 3-month floor. The 5-month capture cap and 30-day floor that appear in older documents were superseded on 2026-08-07 — **do not reason from that pair.**

(!) **Never state this as a flat "we compress everything at 6 months"** either — even about the original file, that over-commits four ways: clips/video are not compressed or replaced at all today (`PAPIC_CLIP_DROP_ENABLED` is opt-in and off); events with no Google Drive connected **hold the originals indefinitely** until a warning is provably sent plus a 7-day grace; Drive-connected events **defer** until the copy is confirmed; and the window is env-overridable. Honest phrasing: originals become **eligible for replacement** at that point, and a weekly sweep swaps them for the compressed copy unless one of those holds applies.

---

## 3. Right-to-erasure interaction (RA 10173 §16)

A user's erasure/account-deletion request (iteration 0025) deletes their personal data **now**, **except** records under a legal-hold floor (classes 3 & 4 — payments, contracts), which are **retained under the legal-obligation basis** and disclosed as such in the privacy policy.

This carve-out is standard and defensible: *"We honor deletion requests except where law requires us to retain financial and contractual records, which we keep for the statutory period and then dispose of."*

---

## 4. Implementation reality (as of 2026-07-11)

Audited against shipped code — **the retention plumbing is greenfield**; almost none of this is enforced yet:

- **Chat** (`chat_threads` / `chat_messages`): text-only, append-only, no attachments. **[OK] UPDATED 2026-07-24 (PR #3634, migration `20270926679942`):** `chat_threads.archived_at` NOW EXISTS. Remove-vendor / withdraw now **archives** (stamps `archived_at`, thread + messages preserved, re-add resumes the same thread) instead of hard-deleting; the `chat_threads` **DELETE RLS policy was REMOVED** → no authenticated user can hard-delete a thread (chat is now an immutable evidence layer). Only service-role paths (retention sweep + RA 10173 erasure) delete. `chat_messages` stays append-only (SELECT+INSERT only). `chat_threads.updated_at` tracks last activity. *(This resolves the old "chat is user-deletable" assumption in the class-1 row above.)*
- **R2 lifecycle: NOT configured** — hot→cold tiering + expiry exist only as prose in `OWNER_ACTIONS.md` and marketing copy. No `wrangler.toml`/Terraform in the repo. **This is the real space program** (media = gigabytes; chat = megabytes).
- **No cleanup cron** touches chat/media. House style deliberately avoids `pg_cron` (uses Vercel cron + on-access sweeps).

- **(!) Compliance gap:** account hard-delete (`admin/users/actions.ts` → `deleteUser`) sets chat user-FKs to NULL but **leaves message bodies (the couple's PII) in `chat_messages` indefinitely** — threads only cascade on *event* delete, and events are never deleted. Fixing this is part of enforcing class 1 & 5.

### Build order to enforce this schedule

1. **Archive (UX, zero deletion)** — add `archived_at` to `chat_thread_reads` (per-user); inbox filter `archived_at IS NULL OR chat_threads.updated_at > archived_at` (Viber-style: a new message un-archives). Ships safely on its own.
2. **R2 lifecycle** — actually configure bucket rules for class 2 (the gigabyte win).
3. **Retention sweep** — weekly Vercel cron `/api/cron/retention-sweep`: hard-delete **class 1 (chat) only** at anchor + 5 y; **skip** any thread/record tied to an active legal hold (class 3/4). Fix the account-deletion residue in the same job.
(!) **CLASS 2 (MEDIA) IS NOT ON THIS SWEEP AND MUST NOT BE ADDED TO IT** (corrected 2026-08-07). Media is handled by `lib/papic-fullres-drop.ts`, which **replaces a file** — it swaps the full-resolution original for its compressed copy and refuses to act when that copy is missing. It does not delete a record, and no photo is ever deleted on a schedule. Wiring class 2 into a hard-delete sweep would destroy galleries we promise to keep for good.

---

## 5. Open items for counsel `[PENDING COUNSEL]`

1. Confirm **BIR retention = 10 years** for in-app SKU payments + Official Receipts (RR 17-2013) and the exact record scope.
2. Confirm **contract retention** period + whether e-signature audit trails (RA 8792) extend it beyond 10 years.
3. Ratify the **5-year period for CHAT** as "necessary" under RA 10173 §11(e).
(!) **Media is NOT on the 5-year clock** — see the Papic media table above. This item said "chat + media" until 2026-08-07, which would have put the wrong number in front of the DPO.
4. Approve the **erasure carve-out** wording (§3) for the privacy policy.
5. Confirm **face-vector** treatment as sensitive personal information and the per-event purge rule.
6. Sign off on **device-fingerprint hashes** (class 10) — legal basis (legitimate interest vs consent), notice wording, and the 24-month rolling-prune period. See the dedicated one-pager `Device_Fingerprint_Data_Use_DPO_Review_2026-07-12.md`.

---

*Related: `[[dpo-designation-owner]]` · `0025_profile_settings/` · `0026_bir_tax_compliance/` · `0032_contract_intelligence/` · `0019_communications/` · `Pricing.md § 2.1` (media storage/longevity ladder).*